A2D 주력 도메인 선정 및 프로젝트 적합성 검증

의사결정 제안서 | 2026년 10월 31일 | A2D / Attack to Defense

> **권고안: 소규모 채용·인재 매칭 웹서비스를 1차 대표 타깃으로 선정한다. A2D 핵심 점검 엔진은 업종 중립으로 유지하고, 채용 도메인은 첫 번째 검증 시나리오로 사용한다.**

조사 범위 2023-10-31 ~ 2026-10-31 (최근 3년) · 기존 사고 조사 엑셀 27건 + 추가 공식 사고 1건 = **총 28개 기록**. 이 수는 확인된 유출 28건을 뜻하지 않는다. 공개 노출, 연구 결과, 원인 미확정 사고, 공격자 주장도 포함된 **문헌 조사 목록**이다. 동일 사업자의 별도 사고는 구분하고, ApplyNow 파급 업체는 원사고와 중복 집계하지 않았다.

기준 문서 팀 제공 「A2D PRD」(2026-10-31), 「A2D 상세 설계」(10p), 기존 「최근 3년 유출·노출 사례 조사」 엑셀. 기술적 해석과 권고는 원문 사실과 구분해 기재한다.

1. 선정 결정 — 왜 채용·인재 매칭인가

1.1 고객 정의

- **핵심 고객:** 자체 웹사이트·API·지원자 파일을 운영하며 개발·서버 운영을 겸임하는 **보안 전담 인력이 부족한 소규모 채용 플랫폼·채용관리 SaaS(ATS)**.
- **대표 사용자:** 보안 비전문 IT 운영자 또는 개발자. 관리자·대표는 위험 점수와 조치 전후 변화를 이해하는 보조 사용자.
- **문제:** 지원자 개인이력·연락처·첨부 문서가 한 서비스에 모이지만, 도메인·API·테스트 서버·파일 저장소의 외부 접근 상태를 일관되게 확인하기 어렵다.
- **선정 방식:** 보안팀의 부재는 대상 고객을 정의한 **시장 가설**이다. 아래 대형 플랫폼 사고들이 곧 '소규모 기업에 보안팀이 없다'는 것을 증명하지는 않는다.

1.2 선택 근거를 4개의 질문으로 검증

판단 질문	이번 조사로 확보한 근거	결론 및 한계
개인정보 유출의 피해 맥락이 뚜렷한가?	알바몬의 임시 이력서 정보, 인크루트의 이력서·자격증 파일 등 채용 특화 데이터가 실제 사고에 포함됨. S04, S05	**예.** 이름·연락처 외 상세 이력과 지원 기록이 보호 대상.
외부 접점에서 문제가 발생한 실제 증거가 있는가?	레쥬메나인의 인증·권한 확인 누락 서버 기능, 해외 ATS의 공개 파일 저장소. S03, S07~S10	**예.** 다만 모든 사고가 동일한 유형은 아님.
현재 A2D 기술로 검증 가능한가?	C-05의 비인증 조회 API, C-01/02의 공개 파일, D-01~05의 자산 탐색을 가상 채용 서비스에 적용 가능.	**부분적으로 예.** S3·Azure·GCS 직접 점검과 BOLA/IDOR는 현재 범위 밖.

판단 질문	이번 조사로 확보한 근거	결론 및 한계
소규모 조직에 점검 수요가 있는가?	KISA가 중소기업 대상으로 홈페이지·운영환경 취약점 점검과 원격 보안점검을 지원. S01, S02	**수요 문제의 제도적 근거.** 타깃 업종의 보안 인력 수·시장 규모는 별도 검증 필요.

1.3 제품 포지셔닝

'채용 플랫폼 전용 취약점 공격기'가 아니라, '개인정보를 처리하는 소규모 웹서비스를 위한 AI 보조 외부 노출 점검기'다. 채용 SaaS가 첫 번째 사례이며, 동일한 엔진을 교육·예약·커머스로 확장한다.

- **도메인 특화 영역:** 자산 중요도 기본값, 지원자 데이터 예시, 한국어 리포트, 표준 조치 가이드, 샌드박스 오류 구성.
- **범용 핵심 엔진:** DNS TXT 소유권 확인, D-01~D-05 자산 발견, C-01~C-17 점검 프레임워크, 위험 점수 산정, 증거 가림, 재점검·변경 추적.

2. 실제 사고와 기술적 유출 경로 — 대표 사례 심층 검증

표기 기준: '유출'은 확인된 무단 정보 접근·반출, '노출'은 누구나 볼 수 있는 상태의 확인, '취약점 검증'은 연구자가 재현했으나 대량 탈취가 입증되지 않은 경우를 뜻한다. '정확한 공격 기법 미공개'는 공백으로 남긴다.

사례	확인된 사건·침입 경로	관찰 가능한 사실과 아직 모르는 것	A2D 연계
레쥬메나인 (한국, 2026)	로그인·권한 검사 누락 서버 기능에 8/19·9/7 외부 접근 → 회원정보 무단 조회. 파일 다운로드 URL 발급 기록도 확인. 원문	**인증·인가 누락은 확인.** URL 발급 ≠ 실제 이력서 파일 다운로드 확정.	**C-05 조건부 관련.** 비인증 GET으로 보호 대상 데이터가 노출되는지 검사. 다른 사용자 권한 우회는 범위 밖.
알바몬 (한국, 2025)	이력서 미리보기 기능의 비정상 접근으로 임시 저장 이력서 정보 22,473건 유출. 원문	기능 경로는 확인. 구체적인 취약점 종류(SQLi/IDOR 등)는 미확정.	C-05와 시나리오 연관. **해당 사고 탐지 가능하다고 단정 금지.**
인크루트 (한국, 2025)	직원 PC 악성코드 감염 → DB 계정정보 탈취 → 내부 시스템 침투 → 약 727.6만 명 정보 및 개인저장파일 54,475건(438GB) 탈취. 원문	개인정보위 조사 결과에 따른 확인된 경로.	현행 웹 EASM **직접 탐지 불가**. 단말·IAM·내부 관제 영역.
나인하이어 (한국, 2026)	기업회원 개인정보 서버에 미허가 접근. 이름·계정 이메일 정보 유출. 원문	**사고 확인, 초기 진입 기술 미공개.** 지원자 개인정보 유출 없다고 회사 설명.	C-05 연관 가능성만; 기법을 가정하지 말 것.
ApplyNow (일본, 2026)	데이터 분석 도구 취약점 악용 → 채용 SaaS DB 무단 접근. 약 39만 명 대상이라는 10/9 갱신 공지. 원문	운영사 공식 공개. 영상·PDF 파일 실체 저장 영역은 이번 접근 대상이 아니라고 밝힘.	**C-13은 버전 확인된 자산에만 제한적.** 외부 공급망 점검은 현행 범위 밖.
HireClick (미국, 2025)	공개 설정이 잘못된 Amazon S3 저장소에 약 570만 파일 접근 가능. 원문	보안 연구 기반 **공개 노출**. 파일 수 ≠ 피해자 수; 실제 악성 탈취 규모 미확정.	**현재 C-01 범위 밖.** '클라우드 공개 버킷' 향후 별도 항목 권장.

사례	확인된 사건·침입 경로	관찰 가능한 사실과 아직 모르는 것	A2D 연계
beWanted (스페인, 2024~25)	Google Cloud Storage 공개 버킷에서 약 110만 파일 노출. 원문	공개 접근은 연구로 확인. 운영사는 악성 탈취 증거가 없다는 입장.	현재 범위 밖, 스토리지 외부 노출 검증 확장 근거.
McHire / Paradox (미국, 2025)	오래된 테스트 관리자 계정의 약한 인증 및 객체별 권한 검증 문제를 연구자가 재현. 원문	잠재 열람 가능 규모 ≠ 실제 유출 규모. 운영사는 비인가 제3자 접근 확인 못했다고 설명.	C-07로 **관리 화면 노출 여부**는 확인 가능하지만, 약한 비밀번호와 BOLA는 현행 범위 밖.

추가 독립 확인: ApplyNow를 이용한 일본 지자체(우오누마시)는 자체 채용 지원 기록 86건과 담당자 등록정보 30건의 유출을 공식 공지했다. 이는 **동일 공급사 사고의 파급 사례**이므로 ApplyNow 사건과 별개 해킹으로 중복 계산하지 않는다. 지자체 공식 발표

사건의 메시지: 확인된 경로는 ① 웹 기능 인증·인가 미흡, ② 지원자 파일 저장소의 공개 설정, ③ 외부 도구·직원 계정의 침해로 분화된다. 이 중 **현재 MVP가 가장 직접적으로 대응하는 것은 ①의 일부인 '비인증 개인정보 API'**다. 다른 사례는 제품 확장 방향 또는 시장의 중요성을 보여주는 근거다.

3. A2D 기존 점검항목과의 적합성 매핑

아래 점검 ID와 P0/P1 구분은 팀의 「A2D 상세 설계」 및 「A2D PRD」를 따른다. **현재 가능한 검사**, **현행 검사로는 사실관계를 단정할 수 없는 경고**, **MVP 범위 밖의 확장**을 분리했다.

점검 ID	PRD 상태	채용 플랫폼 적용	판단 수준 / 구현 유의사항
D-01~D-05 자산 발견	P0	`www`, `api`, `admin`, `staging` 등 소유권 확인 하위 자산과 문서·관리 경로 탐색	자산 존재 확인 ≠ 취약점.
C-01 백업 파일	P0	허가된 웹 경로에 남은 지원자·이력서 백업 파일	공개 파일 형식까지 확인. S3/GCS/Azure 버킷 점검은 아님.
C-02 설정·소스 파일	P0	`.env`, `.git/HEAD` 등에 민감 설정 노출	증거 가림·원문 미보관.
C-04 로그·디버그	P0	지원·접수 API의 디버그 출력·로그 흔적	오류 메시지의 보안 영향은 맥락 검토.
C-05 비인증 개인정보 API	P0	사전 승인된 테스트 지원자 조회 API에 **인증 없이 1회** 요청	결과에 개인정보 패턴 존재 ≠ 무조건 실서비스 정보 유출 확정. 보호 대상임을 검증해야 함.
C-06 API 문서 공개	P0	Swagger/OpenAPI 노출 확인	공개 문서 자체가 항상 취약점은 아님.
C-07 관리 페이지 외부 노출	P0	채용 운영 관리자 로그인 화면 발견	로그인 페이지 접근 ≠ 관리자 권한 탈취.
C-09 TLS	P0	채용 서비스의 HTTPS 인증서·프로토콜	인증서 오류와 실제 데이터 유출을 구분.

점검 ID	PRD 상태	채용 플랫폼 적용	판단 수준 / 구현 유의사항
C-10 보안 헤더	P0	지원·로그인 화면의 헤더 점검	헤더 부재 ≠ 해당 공격 성공 입증.
C-13 알려진 취약 버전	P0	식별된 서버·프레임워크 버전과 오프라인 취약 목록 대조	버전 추정만으로 악용 가능성을 확정하지 말 것.
C-15 잊힌 자산	P0	`dev`, `staging`, `old` 접점 발견	이름·외부 응답만으로 위험이 확정되지는 않음.
C-16 새 자산/노출	P0	재점검에서 신규 지원 API·테스트 자산 변화	변경 기록·알림 후보. 최초 점검만으로 판단하지 않음.
C-03,08,11,12,14,17	이번 MVP 제외	디렉터리 목록·평문 로그인·쿠키·CORS·EOL·메일 인증	상세 설계상 확장 점검 항목.
미정의: Cloud Object Storage	미래 확장	S3·GCS·Azure 버킷의 공개 접근 설정 검사	**기존 C-01에 포함됐다고 주장 금지.** 저장소 소유권·허용 목록 별도 필요.
미정의: BOLA/IDOR	미래 확장	권한 없는 지원자 간 비공개 프로필 조회	승인된 테스트 계정·데이터·접근 경계가 필요. 현재 로그인/식별자 조작 금지.

탐지 가능성 판정 원칙

- **탐지 가능:** 승인된 가상 도메인/엔드포인트에서 허용된 GET·HEAD로 관찰 가능한 신호가 있고, 코드 판정 기준을 충족한다.
- **검토 필요:** 경로·화면의 외부 공개는 확인되나 '인가 누락' 또는 '데이터 유출'을 증명하지 못한다.
- **현재 불가:** 계정 탈취, 직원 PC 악성코드, IDOR/BOLA, 제3자 분석 도구, 클라우드 버킷 설정 등.

4. MVP 검증 시나리오와 PRD 변경안

4.1 시연 환경: 가상 채용·인재 매칭 플랫폼

기존 가상 여행 플랫폼을 **가상 채용 플랫폼**으로 교체할 것을 제안한다. 새 점검 엔진을 만들지 말고, 샌드박스의 서비스 명칭·테스트 엔드포인트·자산 중요도·조치 문장을 바꾼다. 실제 기업 도메인을 점검하지 않는다.

시연 순서	가상의 상태(심어 놓는 결함)	A2D 점검/조치 → 재점검
①	지원자 조회용 **승인된 가상 API**가 비인증 요청에 더미 연락처 응답	C-05가 발견·가린 증거 저장 → 인증 필수로 수정 → 해결됨
②	가상 지원자 백업파일이 웹 공개 경로에 남아 있음	C-01이 노출 확인 → 공개 경로에서 제거 → 해결됨
③	가상의 `.env` 설정 파일 형식이 외부 응답	C-02가 확인 → 공개 차단 → 해결됨
④	테스트 채용 서비스/관리 로그인 경로가 외부 노출	C-15/C-07 발견 → 관리자에게 추가 검토 권고 (접근만으로 침해 확정 아님)

시연 순서	가상의 상태(심어 놓는 결함)	A2D 점검/조치 → 재점검
⑤	조치 전후 조직 위험도가 변경	코드 위험 점수·오늘 할 일 3가지 → FR-09 재점검 → FR-10 추이 표시

A2D의 약속: 코드가 증거를 수집·점수 계산·우선순위를 정하고, LLM은 승인된 도구만 호출해 설명한다. 소유권 확인 전 점검 금지, 허용하지 않은 목적지로 리디렉션 금지, GET·HEAD만, 호스트당 ≤2요청/초, 점검당 ≤300요청, 요청당 ≤10초, 5분 이내, 증거 최대 512바이트·개인정보 마스킹. 이는 최신 PRD의 FR-01~11, NFR-01~09와 동일하다.

4.2 팀의 변경 승인 필요 항목

항목	유지/수정	확인할 의사결정
제품 정의와 핵심 사용자	**수정**	'여행 스타트업' → '소규모 채용 SaaS 운영자', 업종 중립 확장성 문구 명시
FR-02 자산 발견 5종	**유지**	도메인/경로 명칭만 샌드박스에서 채용형으로 구성
FR-03 점검 11종	**유지**	신규 점검 개발보다 판정 정확도 우선. 시간 부족 시 PRD의 7종 축소 정책 사용
FR-05/06 점수·오늘 할 일	**유지 + 설정 수정**	지원자 API 중요도 1.0 등 자산 A 값은 팀 합의·테스트로 확정
FR-07/08 리포트	**유지 + 문구 수정**	채용 운영자에게 이해 가능한 피해·조치 설명; 발견 ID와 연결
FR-09/10 재점검·이력	**유지**	3가지 조치 후 '심각 → 주의 이하' 시연 조건 검증
FR-12/14/15, 실제 도메인 점검	**범위 밖/후순위**	새로운 도메인 리서치 때문에 P0 마감 지연 금지
클라우드 저장소·BOLA 검증	**로드맵**	독립적인 새 점검 ID는 후속 버전에서 결정

5. 주 타깃 선택과 다른 업종으로의 확장

업종	개인정보의 성격	공통 EASM 재사용	별도 확인할 사항
채용·인재 매칭 (주 타깃)	이름·연락처·경력·학력·이력서	웹·API·관리 경로·백업·디버그·취약 버전	지원자 파일/권한 구조의 구체적 운영 방식
교육·학원	학생·보호자 정보, 상담·수강	공통 웹·API 점검 적용 가능	자체 시스템인지 외부 SaaS인지
중소 숙박·예약	예약자 정보, 일정·연락처	공통 웹·API 점검 적용 가능	예약 및 결제 시스템의 책임 범위
소형 커머스	주문·배송·고객정보	공통 웹·API 점검 적용 가능	호스팅 플랫폼이 운영하는 자산과 자체 자산 구분

선택 논리: '채용이 유일하게 보안 위험이 큰 업종'이 아니라 **지원자 데이터의 보호 가치, 확인된 외부 접점 사고, 안전한 샌드박스 재현 가능성, 범용 엔진 재사용**의 결합이 가장 설득력 있는 첫 번째 제품 이야기이기 때문이다. 이는 초기 제품 가설이지 통계적 시장 우위 입증은 아니다.

6. 결론과 팀 승인 요청

최종 추천: ① 주 고객은 소규모 채용·인재 매칭 서비스의 운영·개발 겸직자, ② 가상 채용 플랫폼에서 현재 P0 11종으로 발견→조치→재점검 시연, ③ 이력서 클라우드 저장소 공개·BOLA/IDOR는 사고 사례 기반 후속 로드맵, ④ 교육·예약·커머스는 공통 점검 엔진의 확장 영역으로 둔다.

회의에서 확정할 4가지:

1. 대표 업종/사용자 문구 확정과 PRD 반영 담당자.
2. 가상 여행 플랫폼을 채용 플랫폼으로 바꿀지, 변경 위험이 크면 여행 샌드박스를 유지하고 대표 시나리오만 채용형으로 시연할지 선택.
3. C-05 검증용 승인된 더미 API 및 백업/설정 파일 결함 목록 확정.
4. 제출 전 증거 수준, 오탐 0건, 조치 전후 점수 하락과 자료 출처 점검.

제출 일정 주의: 최신 PRD는 **2026-11-01 13:00 최종 커밋**을 기준으로 한다. 타깃 변경은 기존 P0 구현과 안전 제한을 깨지 않는 수준으로 결정해야 한다.

부록 A. 기존 사고 조사 엑셀 28개 기록 전체

데이터 출처: `A2D_채용플랫폼_개인정보유출_최근3년_28건.xlsx` (`사고사례_27건`, `추가공식사례` 시트). 원본 엑셀 파일

- **A** 기존 조사에서 정부·운영사 공지 등으로 분류, **B** 언론·연구 보고서, **C** 이견/미확정, **D** 공격자 주장 중심. 이 등급은 팀 내부 자료의 **출처 신뢰도 표지**이지 사실의 확률이나 전문적 인증 등급이 아니다.
- 아래 각 행은 기존 엑셀을 전재한 **조사 목록**이다. 대표 사례는 위에서 추가 검증했지만, 28개 항목 모두의 최신 사후 조사 결과·링크 유효성까지 개별 보장하는 목록은 아니다.
- **노출 파일 개수 ≠ 유출 피해자 수, 외부 접근 가능 ≠ 악성 탈취 확인**. 운영사의 반박이나 기술 원인 미공개는 그대로 유지한다.

	#	사례 / 시기	유출 경로·상태 (엑셀 요약)	기존 자료의 A2D 연결	근거
	01	**레쥬메나인 (RESUME9)** (한국, 2026-09)	로그인·권한 검증 누락 서버 기능에 외부 접근; 이력서 다운로드 URL 발급 기록. 실제 다운로드는 조사 중	C-05 조건부; 파일 URL 발급 검사 확대	A · 원문
	02	**나인하이어** (한국, 2026-09)	회원정보 저장 서버 미허가 접근; 회원조회 기능 악용 차단. 정확한 침입 기술은 비공개	C-05 관련 가능성; 실제 원인 불확실	B · 원문

#	사례 / 시기	유출 경로·상태 (엑셀 요약)	기존 자료의 A2D 연결	근거
03	**비즈니스피플** (한국, 2026-03)	홈페이지 특정 페이지 공격. IP 차단·페이지 운영중지·패치. 정확한 기법 미공개	외부 경로 탐지는 관련; 구체적 취약점 직접 탐지 여부 불명	B · 원문
04	**캐치 / 캐치캠퍼스** (한국, 2026-03)	신규 서비스 특정 페이지의 기술적 결함 악용, 비인가 접근 후 데이터 추출	D-05/C-05 연관 가능; 원인 미상	B · 원문
05	**119고시 (소방청 채용 사이트)** (한국, 2025-10)	해킹 의심, 위탁관리사 조사. 최초 침입 경로 미확정	D-01/05 자산 확인 가능; 원인 직접 검출 근거 부족	B · 원문
06	**알바몬** (한국, 2025-04)	이력서 미리보기 기능에서 비정상 접근·해킹 시도	C-05 조건부; 이력서 미리보기 권한 검사는 추가 검증 필요	A · 원문
07	**인크루트** (한국, 2025-01)	개인정보 취급 PC 악성코드 → 계정 탈취 → 내부 시스템 접근 → 약 1개월 DB 대량 유출	현재 외부 EASM 불가; 내부 계정·망·행동 관제 필요	A · 원문
08	**KS한국고용정보** (한국, 2025-04)	내부 인사관리 시스템 무단 접근. 초기 진입 경로 미확정	외부 EASM로 내부 침해 예방 입증 불가	B · 원문
09	**한화엔진 채용** (한국, 2025-09)	채용 담당자의 이메일 수신자 지정 오류	현재 EASM 불가; DLP/메일 정책 영역	B · 원문
10	**ApplyNow / Interview Cloud / ApplyNow Sign** (일본, 2026-08)	도입된 데이터 분석 도구의 취약점 악용 → 채용 DB 무단 접근. 계약 종료 고객 정보도 잔존	C-13은 식별된 취약 버전 한정; 공급망·제3자 확장 필요	A · 원문
11	**Talentsconnect** (독일, 2026-06)	연구진: 인증 없는 MongoDB, 약 11GB/843개사 관련, 335개 자격증명. 업체: 테스트 시스템·가짜 데이터, 실지원자 유출 부인	현재 80/443 HTTP 기반만으로 DB 점검 불가; 확대 대상	C · 원문
12	**TalentHook** (미국, 2025-07)	잘못 설정된 Azure Blob Storage 컨테이너에 인증 없이 접근 가능	C-01 웹 루트와 별개; 클라우드 저장소 점검 확대	B · 원문
13	**LiveCareer** (글로벌, 2025-07)	Microsoft Azure Storage 컨테이너 공개 설정	C-01 범위 외; 저장소 점검 확대	B · 원문
14	**HireClick** (미국, 2025-05)	Amazon S3 버킷 잘못된 공개 설정	C-01 범위 외; 저장소 점검 확대	B · 원문

#	사례 / 시기	유출 경로·상태 (엑셀 요약)	기존 자료의 A2D 연결	근거
15	**beWanted** (스페인, 2024-11)	Google Cloud Storage 버킷 공개, 2025-05 폐쇄. 회사는 외부 악성 탈취 증거 없다고 발표	C-01 범위 외; 저장소 점검 확대	B · 원문
16	**Foh&Boh** (미국, 2024-09)	AWS S3 버킷 노출; 2025-01 폐쇄	C-01 범위 외; 저장소 점검 확대	B · 원문
17	**Valley News Live 취업 포털** (미국, 2025-02)	AWS S3 버킷 공개 접근	클라우드 저장소 점검 확대	B · 원문
18	**McHire / Paradox.ai** (미국, 2025-07)	약한 테스트 계정과 예측 가능한 ID를 통해 지원자 대화 정보 접근; 운영사 대량 탈취 부인	인증 테스트/ID 변경 금지로 현행 A2D 직접 검증 불가	B · 원문
19	**Naukri** (인도, 2025-05)	iOS/Android 앱용 API가 채용 담당자 이메일 정보를 반환. 회사 측 의도적 공개 기능 주장	C-05 조건부, 공개 데이터와 취약점 구분 필요	C · 원문
20	**Manpower Lansing 가맹점** (미국, 2024-12)	랜섬웨어 침입 후 네트워크 파일 탈취. 최초 진입 경로는 미공개	외부 EASM 탐지 가능 근거 없음	B · 원문
21	**ICAO 채용 DB** (국제, 2025-01)	채용 DB 기록 불법 공개 주장, 운영기관 조사. 최초 침입 방식 미공개	외부 EASM 탐지 가능 여부 판단 불가	B · 원문
22	**France Travail / Cap Emploi** (프랑스, 2024-02)	사회공학으로 상담원 암호 재설정 → 계정 탈취 → 과도한 열람권한으로 대량 추출	외부 EASM 불가; 인증·권한·로그 관제 영역	A · 원문
23	**France Travail / Kairos** (프랑스, 2025-07)	교육기관 파트너 계정이 infostealer로 탈취 → Kairos 정보 조회	외부 EASM 직접 방지 불가; 계정 보안 확장	B · 원문
24	**DomeWatch 채용 지원서 DB** (미국, 2025-10)	인증 없는 데이터베이스 공개; 악의적 접근 여부는 미확인	현행 D-02 경로만으로 검증 불가; DB 자산 확대	B · 원문
25	**Bullhorn** (미국, 2026-10)	사이버 침해 대응으로 ATS 중단·계정 보안 조치; 정보 탈취 여부 미확정	유출 확정 사례로 인용 금지	C · 원문
26	**FBIJobs / Oracle PeopleSoft** (미국, 2026-09)	공격자가 PeopleSoft 취약점 이용 주장; 외주업체 패치 누락 관련 보도. 공격 기법 세부 미확정	C-13 취약 버전 확인 필요; 실제 탐지 가능성 불명	C · 원문
27	**Glassdoor** (미국, 2026-09)	랜섬웨어 그룹이 침해·자료 공개 협박; 샘플·출처·유출사실 불확정	단정 금지·시장 배경 참고만	D · 원문

	#	사례 / 시기	유출 경로·상태 (엑셀 요약)	기존 자료의 A2D 연결	근거
	28	**France Travail / Missions Locales** (프랑스, 2025-12)	지역 취업지원기관 관리자 계정 탈취 → 공격자가 ProConnect 계정 2개 생성 → 업무 시스템에서 청년 구직자 정보 열람	현재 A2D 비침습 웹 EASM으로 직접 탐지 불가; 권한 관리·비정상 계정 생성 감시 필요	A · 원문

부록 B. 핵심 확인 출처 및 문서 해석 기준

팀 내부 기준: 「A2D PRD」(2026-10-31) 및 「A2D 상세 설계」(점검 D-01~05, C-01~17, FR/NFR 제한). 원본은 팀 보유 자료이고 웹 공개문서가 아니다.

핵심 외부 출처(클릭 시 원문 이동):

- **S01** 한국인터넷진흥원 · 중소기업 보안취약점 점검 지원
- **S02** 한국인터넷진흥원 · 내서버 돌보미(중소기업 원격보안점검)
- **S03** 레쥬메나인 · 서버 권한 검증 누락 사고 보도, 2026.09.14
- **S04** 알바몬 · 이력서 미리보기 비정상 접근 보도, 2025.05.02
- **S05** 인크루트 · 개인정보위 조사 결과 보도, 2025.10.23
- **S06** ApplyNow 운영사 공식 공지(10월 9일 추가 발표)
- **S07** HireClick · Amazon S3 공개 설정 연구 보도
- **S08** beWanted · GCS 공개 버킷 보안 연구
- **S09** LiveCareer · Azure 공개 저장소 보안 연구
- **S10** Foh&Boh · AWS 스토리지 공개 보안 연구
- **S11** McHire / Paradox · 보안 연구 및 회사 설명
- **S12** 나인하이어 · 기업회원 정보 유출 보도
- **S13** 일본 우오누마시 · ApplyNow 관련 지자체 공식 발표
- **S14** 개인정보위 · 알바몬 사고 조사 착수 보도

해석 원칙: (1) 공식 사고 확인과 언론·보안연구 주장 분리, (2) 파일 수·사람 수·잠재 접근 규모 구분, (3) '공개된 서버 경로'와 '권한 검증 누락'을 혼동하지 않음, (4) 확인되지 않은 SQLi·BOLA·초기 침입 경로는 추정 금지, (5) 특정 기업에 보안팀이 없는지는 별도 조사, (6) A2D가 직접 예방할 수 있었던 사고라는 반사실적 주장은 하지 않음.

이 문서의 역할: 도메인 선정 및 MVP 적합성 의사결정용. 실서비스에 대한 취약점 진단 결과나 법적 책임 판정이 아니다.